



ROAD TO HALL OF FAME

Bypass de Filtro Mediante Ruta Absoluta

Actividad 08 · Reporte de laboratorio

Ingeniería en Tecnologías de la Información

Universidad Politécnica de San Luis Potosí

Fundamentos de Ciberseguridad

Mtro. Servando López Contreras

21 de septiembre de 2026



Road to Hall of Fame — Bypass de Filtro Mediante Ruta Absoluta

1. Datos generales del laboratorio

Nombre del laboratorio	File path traversal, traversal sequences blocked with absolute path bypass
Nivel	Practitioner
Tipo de explotación	Path Traversal / Directory Traversal — bypass de filtro mediante ruta absoluta
Objetivo del laboratorio	Obtener el contenido del archivo /etc/passwd explotando el parámetro "filename", evadiendo el filtro que bloquea las secuencias "../".
URL del laboratorio	https://portswigger.net/web-security/file-path-traversal/lab-absolute-path-bypass

2. Explicación técnica de la vulnerabilidad

Este laboratorio es una variante más protegida del caso simple de Path Traversal. La aplicación bloquea activamente las secuencias de salto de directorios ("../") en el parámetro filename: si se envía un payload como ../../etc/passwd, la aplicación detecta el patrón y responde con un error, tratando el valor recibido como relativo a un directorio de trabajo por defecto.

Sin embargo, el filtro implementado solo contempla rutas relativas (las que dependen de "../" para escapar del directorio base). No valida si el valor recibido es, en cambio, una ruta absoluta del sistema de archivos, es decir, una ruta que comienza directamente desde la raíz ("/"). Como el servidor utiliza el valor recibido para localizar el archivo sin verificar su origen, si se le proporciona una ruta absoluta, el sistema operativo la resuelve directamente sin necesidad de "escapar" de ningún directorio mediante "../".

En otras palabras, el filtro busca específicamente el patrón "../" para bloquear el ataque (una defensa basada en lista negra o blacklisting), pero no contempla que el mismo objetivo puede lograrse sin usar ese patrón, simplemente conociendo la ruta absoluta del archivo deseado. Esta

vulnerabilidad también se clasifica dentro de OWASP Top 10 como parte de A01:2021 – Broken Access Control.

3. Procedimiento paso a paso

- Abrir Burp Suite Community Edition y crear un "Temporary project in memory" con la configuración por defecto.
- En Proxy > HTTP history, dar clic en "Open browser" para abrir el navegador Chromium integrado, que enruta automáticamente el tráfico a través de Burp.
- Dentro de ese navegador, acceder a la URL del laboratorio (lab-absolute-path-bypass) e iniciar sesión con la cuenta de PortSwigger; dar clic en "Access the lab".
- En la tienda ("We Like To Shop"), dar clic en "View details" de cualquier producto para generar tráfico hacia el servidor.
- Ajustar nuevamente el filtro de HTTP history: al ser un proyecto nuevo de Burp, el filtro regresó a su configuración por defecto ("Hiding CSS and image content"). Fue necesario marcar la casilla "Images" en "Filter by MIME type" y quitar las extensiones jpg/png del campo "Hide", igual que en la actividad anterior.
- Con el filtro corregido, localizar en HTTP history una petición GET /image?filename=NOMBRE.jpg (por ejemplo, filename=1.jpg).
- Seleccionar esa petición, clic derecho → "Send to Repeater", e ir a la pestaña Repeater.
- En Repeater, reemplazar el valor del parámetro filename por una ruta absoluta: /etc/passwd (a diferencia del laboratorio anterior, aquí NO se utilizan secuencias "../").
- Enviar la petición (Send / Ctrl+Enter) y revisar el panel de respuesta: el servidor devuelve "HTTP/2 200 OK" con el contenido completo de /etc/passwd, confirmando que el filtro de "../" fue evadido exitosamente.

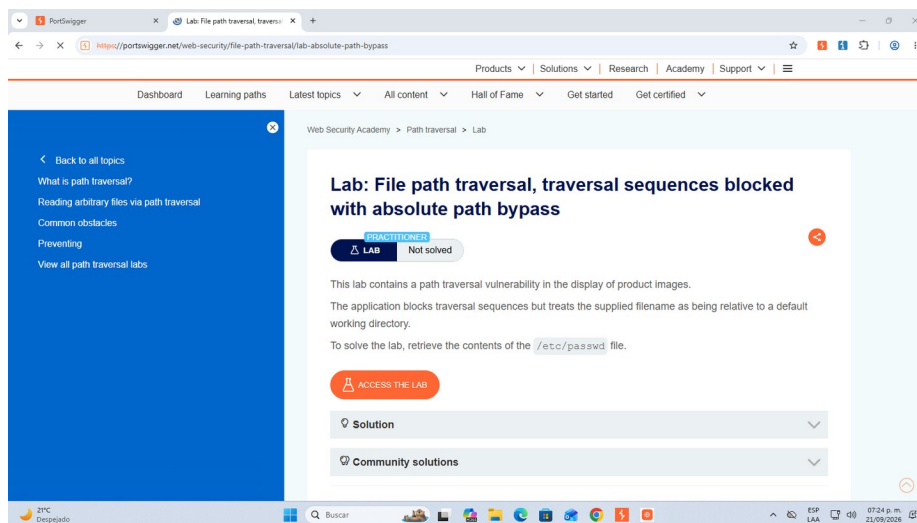
- Regresar a la pestaña del laboratorio en PortSwigger, refrescar la página y confirmar que el estatus cambia de "Not solved" a "Solved".

4. Evidencias fotográficas del proceso

A continuación se documenta, en orden cronológico, cada paso realizado durante la explotación del laboratorio, con su captura de pantalla correspondiente.

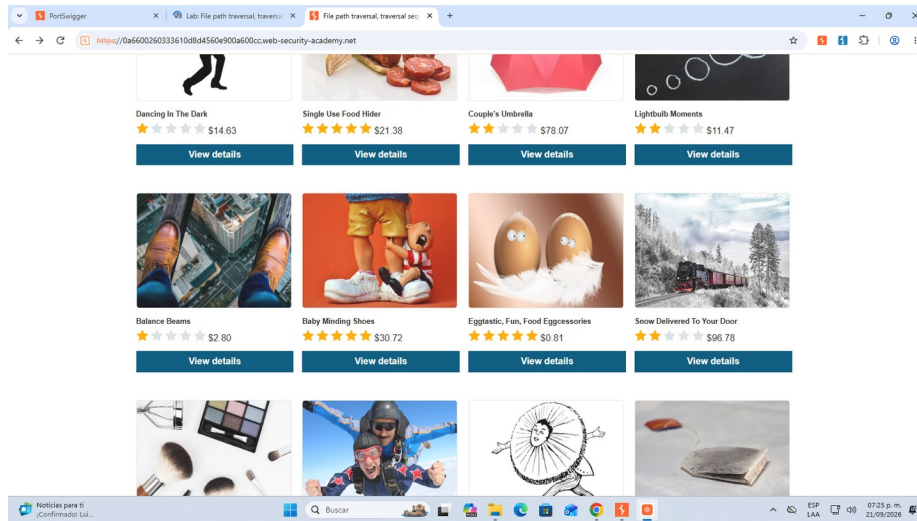
4.1 Página del laboratorio (estado inicial)

Página oficial del laboratorio en PortSwigger, mostrando el nivel "Practitioner", el estado inicial "Not solved" y la descripción del reto: la aplicación bloquea las secuencias de traversal pero trata el filename como relativo a un directorio de trabajo por defecto.



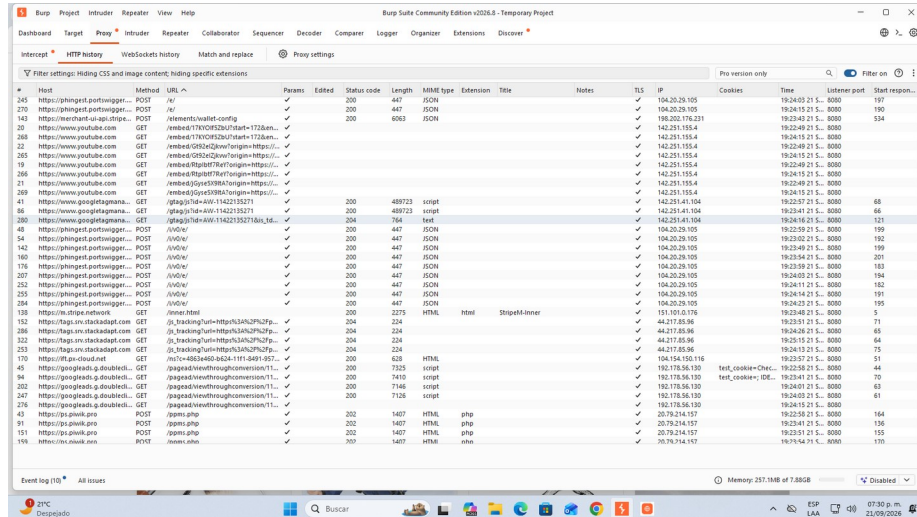
4.2 Generación de tráfico en la tienda

Se accedió a la tienda ("We Like To Shop") y se navegó entre los productos para generar peticiones GET /image?filename= hacia el servidor, necesarias para poder interceptarlas en Burp.



4.3 Filtro de Burp ocultando las imágenes

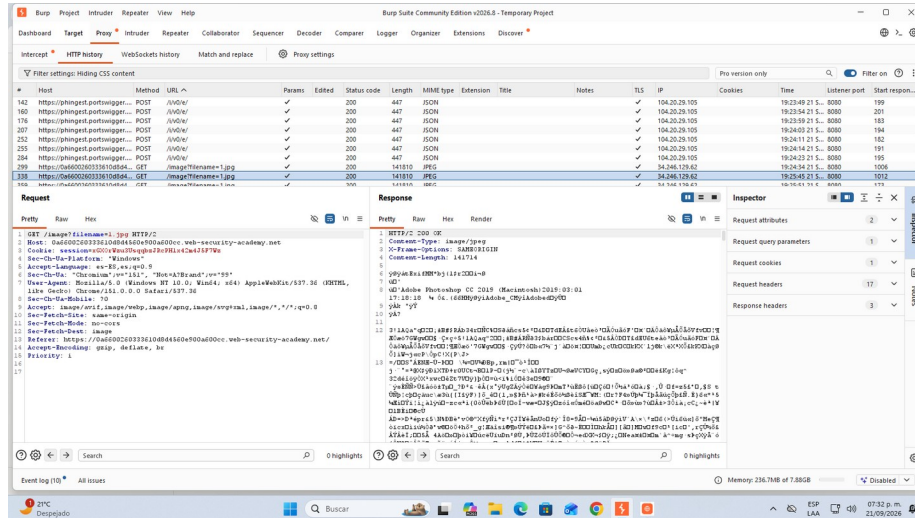
Al ser un proyecto nuevo en Burp Suite, el filtro de HTTP history regresó a su configuración por defecto ("Hiding CSS and image content; hiding specific extensions"), por lo que las peticiones a archivos de imagen no eran visibles en la lista.



Solución aplicada: se repitió el ajuste de filtro de la actividad anterior, marcando "Images" en "Filter by MIME type" y quitando jpg/png del campo "Hide".

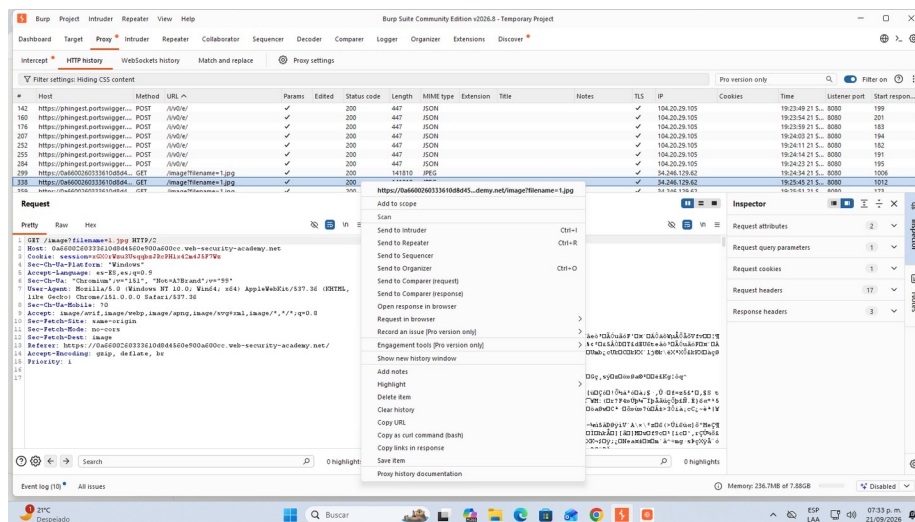
4.4 Request interceptado

Con el filtro corregido, se localizó y seleccionó la petición GET /image?filename=1.jpg en el HTTP history de Burp, visible junto con su request y response completos (esta es la petición original, antes de modificarla).



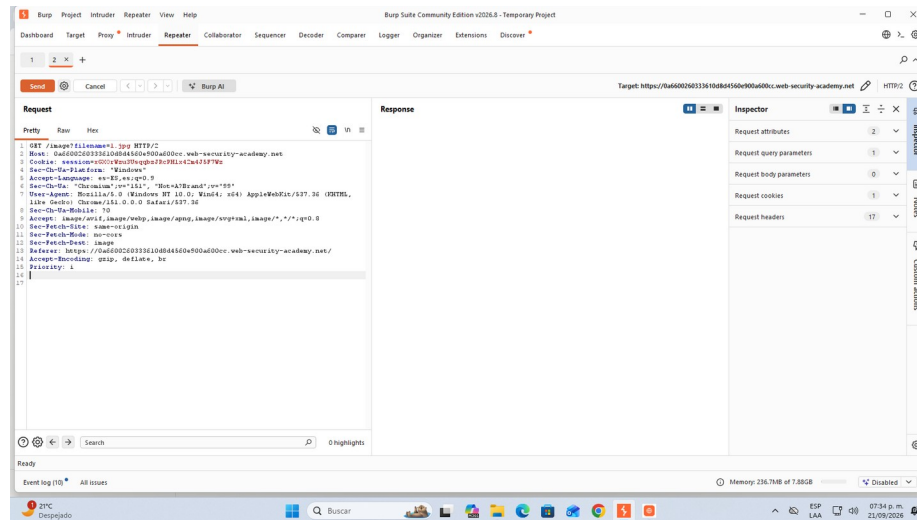
4.5 Envío de la petición a Repeater

Se hizo clic derecho sobre la petición seleccionada y se eligió la opción "Send to Repeater" del menú contextual, para poder modificar y reenviar la petición manualmente.



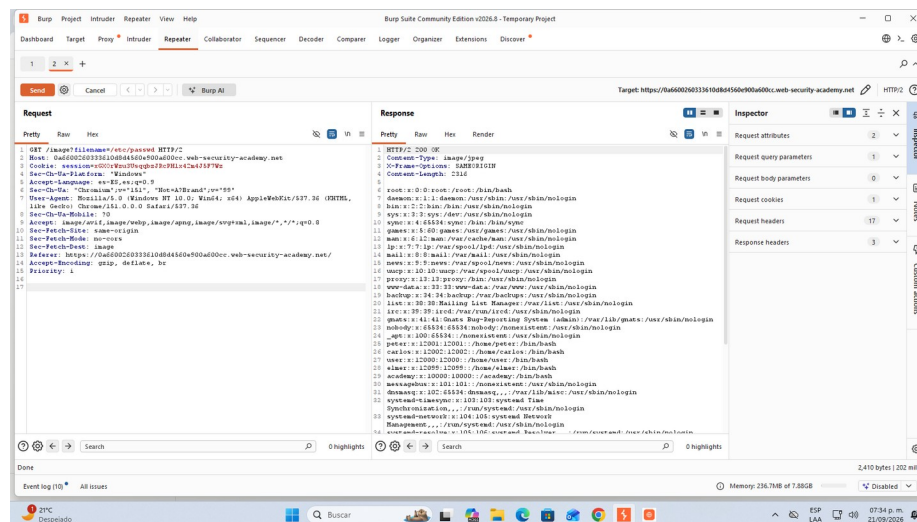
4.6 Petición cargada en Repeater

La petición `GET /image?filename=1.jpg` quedó cargada en una nueva pestaña de Repeater, lista para ser modificada con el payload de bypass.



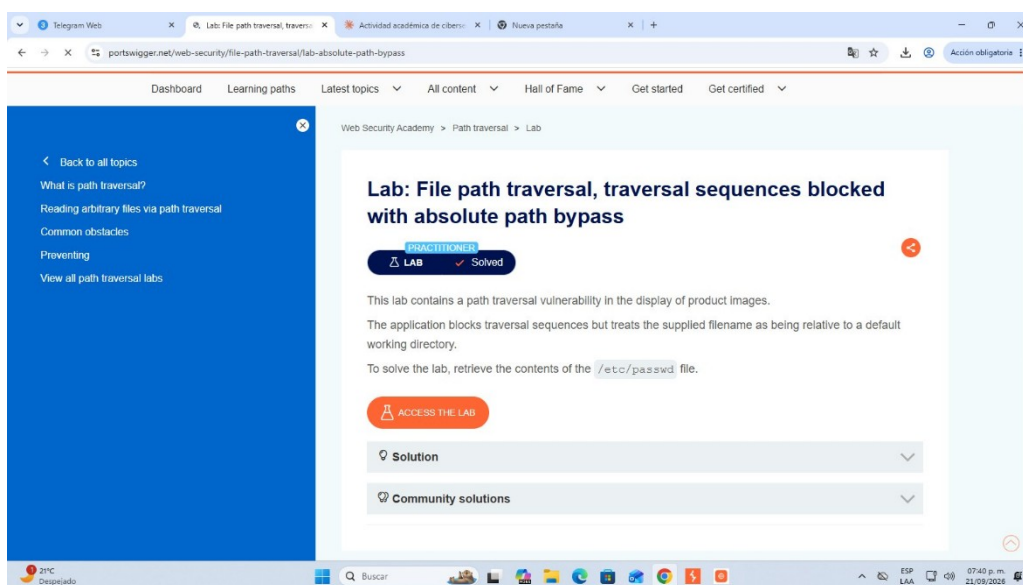
4.7 Payload de ruta absoluta y respuesta vulnerable

Se reemplazó el valor del parámetro `filename` por la ruta absoluta `/etc/passwd` (sin usar `../`). Al enviar la petición, el servidor respondió "HTTP/2 200 OK", devolviendo el contenido completo del archivo `/etc/passwd` y confirmando que el filtro de secuencias de traversal fue evadido con éxito.



4.8 Confirmación "Lab Solved"

Captura del navegador mostrando el banner verde de PortSwigger indicando que el laboratorio fue resuelto ("Solved"), confirmada al refrescar la página del laboratorio tras el ataque exitoso.



5. Explicación del payload

Payload utilizado: /etc/passwd

- A diferencia del laboratorio anterior, este payload no utiliza ninguna secuencia de salto de directorios ("../"); es simplemente la ruta absoluta del archivo objetivo dentro del sistema de archivos del servidor.
- El filtro de la aplicación está diseñado para detectar y bloquear específicamente el patrón "../", asumiendo que esa es la única forma de "escapar" del directorio de imágenes por defecto.
- Sin embargo, la aplicación no valida si la cadena recibida ya es una ruta absoluta. Al recibir /etc/passwd, el sistema operativo interpreta ese valor como la ruta completa desde la raíz del sistema de archivos, ignorando por completo el directorio base de imágenes donde la aplicación esperaba operar.

- Esto evidencia una debilidad típica de las defensas basadas en listas negras (blacklisting): bloquear un patrón conocido no garantiza que no existan otras formas de lograr el mismo resultado.

6. Incidencias durante la práctica

- Filtro de contenido reiniciado: al crear un nuevo proyecto temporal en Burp Suite para este laboratorio, el filtro de HTTP history volvió a su configuración por defecto, ocultando nuevamente las peticiones de imagen. Fue necesario repetir el ajuste de "Filter by MIME type" y "Filter by file extension" realizado en la actividad anterior.
- Confusión inicial sobre el estado del laboratorio: tras obtener una respuesta "200 OK" con el contenido de /etc/passwd en Repeater, la página del laboratorio todavía mostraba "Not solved", ya que esa captura correspondía al estado previo al ataque. Al refrescar la página del laboratorio después de la explotación exitosa, el estatus cambió correctamente a "Solved".

7. Mitigación recomendada

- No basta con bloquear el patrón "../"; también se debe rechazar cualquier entrada que constituya una ruta absoluta (que comience con "/" en sistemas Linux/Unix, o con una letra de unidad como "C:\" en Windows).
- Utilizar listas blancas (whitelisting) de nombres de archivo permitidos, en lugar de intentar detectar y bloquear patrones maliciosos específicos (blacklisting), ya que este enfoque es inherentemente incompleto.

- Canonicalizar la ruta recibida (resolver la ruta real, por ejemplo con funciones como `realpath()`) y verificar que el resultado final se encuentre dentro del directorio permitido, sin importar cómo se haya construido el input original.
- Usar identificadores indirectos (por ejemplo, un ID numérico mapeado internamente a la ruta real del archivo) en lugar de aceptar directamente nombres o rutas de archivo proporcionados por el usuario.
- Aplicar el principio de mínimo privilegio, ejecutando la aplicación con permisos de sistema de archivos restringidos para limitar el impacto de una posible lectura no autorizada.

8. Conclusión

Este laboratorio permitió comprender que las defensas basadas únicamente en la detección de patrones específicos (como bloquear "../") son insuficientes para prevenir vulnerabilidades de Path Traversal. Se demostró de forma práctica cómo una ruta absoluta puede evadir por completo un filtro diseñado solo para secuencias relativas, reforzando la importancia de validar la ruta final resuelta (canonicalización) en lugar de simplemente filtrar patrones de entrada conocidos.

Referencias

PortSwigger. (2026). File path traversal, traversal sequences blocked with absolute path bypass [Laboratorio interactivo]. Web Security Academy.

<https://portswigger.net/web-security/file-path-traversal/lab-absolute-path-bypass>

OWASP Foundation. (2021). OWASP Top 10:2021 – A01 Broken Access Control.

https://owasp.org/Top10/A01_2021-Broken_Access_Control/